



University
of Essex

60

WHERE CHANGE HAPPENS 1964–2024

IRINA STEPHANIE



RESEARCH PROPOSAL **IDENTITY AND ACCESS** **GOVERNANCE IN** **MICROSOFT AZURE**

CONTEXT AND
JUSTIFICATION

SIGNIFICANCE, CONTRIBUTION
AND RESEARCH PROBLEM



**EXPERIMENTAL EVALUATION OF IAM MECHANISMS FOR
SECURING API ACCESS IN A VULNERABLE CLOUD
ENVIRONMENT ACCORDING TO ZERO TRUST PRINCIPLES**



CONTEXT AND JUSTIFICATION



- 🌐 CLOUD-NATIVE MIGRATION
- 🎯 IDENTITIES = MAJOR TARGETS
- 🔒 ZERO TRUST MODEL (ZT)
- 🛡️ AZURE ENTRA ID
- ⚠️ PERSISTENT OPERATIONAL CHALLENGES
- ❗ FEW EMPIRICAL EVALUATIONS

[KODAKANDLA, 2024]
[SHORE, ZEADALLY & KESHARIYA, 2021]
[NIST SP 800-207; CHANDRAMOULI & BUTCHER, 2023]
[KODAKANDLA, 2024]
[BUSH & MASHATAN, 2022]
[BOBBERT & SCHEERDER, 2022; LEVINE & TUCKER, 2023]

SIGNIFICANCE, CONTRIBUTION
AND RESEARCH PROBLEM

KEY LITERATURE (1/2)



RESEARCH OBJECTIVE

→ TEST ENTRA ID IAM ON A VULNERABLE APPLICATION
(BROKEN CRYSTAL)

→ ASSESS EFFECTIVENESS IN A REAL SCENARIO
(LEVINE & TUCKER, 2023)



SIGNIFICANCE, CONTRIBUTION AND RESEARCH PROBLEM



PROBLEM

"TO WHAT EXTENT DO THE IAM MECHANISMS OFFERED BY **MICROSOFT ENTRA ID** CONCRETELY ENHANCE THE SECURITY, TRACEABILITY, AND GOVERNANCE OF **API ACCESS IN A VULNERABLE CLOUD ENVIRONMENT** WHEN IMPLEMENTED AND ASSESSED **ACCORDING TO THE ZERO TRUST MODEL**?"



HYPOTHESIS

"THE RIGOROUS AND CONTEXTUALIZED APPLICATION OF THE **IAM MECHANISMS PROVIDED BY MICROSOFT ENTRA ID** SIGNIFICANTLY IMPROVES THE SECURITY OF EXPOSED **API ACCESS IN A VULNERABLE CLOUD ENVIRONMENT** THROUGH EARLY DETECTION OF ABNORMAL BEHAVIORS AND FINER ACCESS GOVERNANCE, **IN ACCORDANCE WITH THE CORE PRINCIPLES OF THE ZERO TRUST MODEL**."

KEY LITERATURE {1/2}

CONTRIBUTION & ORIGINALITY



EXPERIMENTAL APPROACH



COMBINATORIAL APPROACH



MULTI-PERSONA METHODOLOGY



PRACTICAL RECOMMENDATIONS



ACADEMIC ANCHORING

GENERAL STRUCTURE & ARTICULATION



TECHNICAL FOUNDATION

→ ENTRA ID IAM ON APIS



THEORETICAL FRAMEWORK

→ ZERO TRUST



EXPERIMENTAL FIELD

→ AZURE TENANT



APPLICATION ENVIRONMENT

→ BROKEN CRYSTAL

KEY LITERATURE {2/2}



KEY LITERATURE (1/2)



COMPREHENSIVE BUT UNEVENLY MASTERED IAM

RBAC GRANULARITY - ROSE & SHORE (2021), BUSH & MASHATAN (2022)
PIM (PRIVILEGED IDENTITY MGMT) - LEVINE & TUCKER (2023)
MFA (MULTIFACTOR AUTHENTICATION) - SHORE ET AL. (2021), MICHAEL (2022)
DEPLOYMENT CONSISTENCY - BUSH & MASHATAN (2022), MICHAEL (2022)

KEY LITERATURE (2/2)



API SECURITY: AN UNDERSTUDIED ANGLE

API AS ATTACK SURFACE - TEERAKANOK & UEHARA (2021)
GRANULARITY OF CONTROLS - SHORE ET AL. (2021)
TOKEN MANAGEMENT - TEERAKANOK & UEHARA (2021)
EXPERIMENTAL EVIDENCE - LEVINE & TUCKER (2023)

AIMS & OBJECTIVES



KEY LITERATURE [2/2]

AIMS & OBJECTIVES

METHODOLOGY AND RESEARCH DESIGN



ZERO TRUST VS. OPERATIONS TENSIONS



LEAST PRIVILEGE & CONTINUOUS VERIFICATION - MICHAEL ET AL. [2022], BUSH & MASHATAN [2022]
TOKEN ROTATION - TEERAKANOK & UEHARA [2021]
CONFIGURATION CONSISTENCY - LEVINE & TUCKER [2023]

API GOVERNANCE



LACK OF EXPERIMENTAL EVALUATIONS

IDEAL ASSUMPTIONS - LEVINE & TUCKER [2023]
CONDITIONAL ACCESS COMPATIBILITY - TEERAKANOK & UEHARA [2021]
TOKEN LIFETIME REDUCTION - SHORE ET AL. [2021]
RBAC AUDITING - BUSH & MASHATAN [2022]
INDEPENDENT VALIDATION - MICHAEL ET AL. [2022]



SYNTHESIS AND GAPS

IAM = ESSENTIAL BUT COMPLEX - SHORE ET AL. [2021], MICHAEL ET AL. [2022]
AZURE CONFIGURATION DISPERSION - BUSH & MASHATAN [2022]
SECURITY VS. PRODUCTIVITY TENSION - LEVINE & TUCKER [2023]
NO SYSTEMATIC TESTING - MICHAEL ET AL. [2022]
RESEARCH OBJECTIVE - TEERAKANOK & UEHARA [2021]

AIMS & OBJECTIVES

IAM IMPLEMENTATION (NIST SP 800-207 - ROSE ET AL., 2020; SHORE ET AL., 2021; BUSH & MASHATAN, 2022)

EXPERIMENTAL ENVIRONMENT (MICHAEL ET AL., 2022; LEVINE & TUCKER, 2023)

MULTI-PERSONA SIMULATION (LEVINE & TUCKER, 2023; BUSH & MASHATAN, 2022)
CONTROLLED ATTACK SCENARIOS (TEERAKANOK & UEHARA, 2021; SHORE ET AL., 2021)

METHODOLOGY AND RESEARCH DESIGN

ZERO TRUST EVALUATION (LEAST PRIVILEGE, AUDITABILITY) (ROSE ET AL., 2020; SHORE ET AL., 2021; MICHAEL ET AL., 2022)
IDENTITY LIFECYCLE ANALYSIS (SHORE ET AL., 2021; LEVINE & TUCKER, 2023)

IDENTIFICATION OF LIMITATIONS (BUSH & MASHATAN, 2022; MICHAEL ET AL., 2022)
PRACTICAL RECOMMENDATIONS (SHORE ET AL., 2021; LEVINE & TUCKER, 2023)

RESEARCH QUESTIONS AND ANALYTICAL ANGLES (1/2)

METHODOLOGY AND RESEARCH DESIGN

2 SECURITY ALERTS

RESEARCH QUESTIONS AND ANALYTICAL ANGLES [1/2]

RESEARCH QUESTIONS AND ANALYTICAL ANGLES [2/2]



OVERALL APPROACH



MIXED EXPERIMENTAL DESIGN



DATA COLLECTION

EXPLORATORY

EXPERIMENTAL EVALUATIVE

CASE STUDY
CONTROLLED EXPERIMENTATION

SCENARIO-BASED SIMULATION
COMPARATIVE APPROACH

DIRECT OBSERVATION OF ACCESS
AZURE LOGS

SCREENSHOTS AND EXPORTS
DOCUMENT ANALYSIS



METHODOLOGY AND RESEARCH DESIGN

⚠️ 2 SECURITY ALERTS

RESEARCH QUESTIONS AND ANALYTICAL ANGLES [1/2]

RESEARCH QUESTIONS AND ANALYTICAL ANGLES [2/2]



DATA TYPOLOGY



ANALYTICAL PROCESSING



QUALITY AND RELIABILITY VALIDATION

PRIMARY DATA
SECONDARY DATA

QUANTITATIVE DATA
QUALITATIVE DATA

TRIANGULATION OF CONFIGURATIONS / SCENARIOS / LOGS

ZERO TRUST ANALYSIS FRAMEWORK
EFFECTS OF IAM CONTROLS

ITERATIVE CROSS-CHECKING
CROSS-ANALYSIS OF DATA

FULL TRACEABILITY



RESEARCH QUESTIONS AND ANALYTICAL ANGLES (1/2)

RESEARCH QUESTIONS AND ANALYTICAL ANGLES (2/2)

ETHICAL
CONSIDERATIONS,
SCOPE AND
DELIVERABLES

ACCESS CONTROL AND PRIVILEGES

{NIST SP 800-207 - ROSE ET AL., 2020}

{MICROSOFT DOCS - AZURE AD IDENTITY GOVERNANCE}

TRACEABILITY AND AUDITABILITY

{NIST SP 800-207 - ROSE ET AL., 2020}

{MICROSOFT DOCS - AZURE SENTINEL & IDENTITY PROTECTION}

CONTEXTUAL ACCESS

{MICROSOFT LEARN - WHAT IS CONDITIONAL ACCESS?}

IDENTITY LIFECYCLE

{GDPR - EUROPEAN UNION, 2016}

{MICROSOFT DOCS - LIFECYCLE WORKFLOWS}

SECURITY VS. USER EXPERIENCE

{MICROSOFT DOCS - PRIVILEGED IDENTITY MANAGEMENT; MFA}



RESEARCH QUESTIONS AND ANALYTICAL ANGLES [2/2]

ETHICAL
CONSIDERATIONS,
SCOPE AND
DELIVERABLES

TIMELINE



ATTACK SURFACE REDUCTION

[NIST SP 800-207 - ROSE ET AL., 2020]

[MICROSOFT DOCS - CONDITIONAL ACCESS POLICIES]

ZERO TRUST COMPLIANCE

[NIST SP 800-207 - ROSE ET AL., 2020]

IAM INCIDENT RESPONSE

[MICROSOFT DOCS - IDENTITY PROTECTION RISK DETECTIONS]

AZURE WORKLOAD INTEROPERABILITY

[MICROSOFT DOCS - SECURE ACCESS; MICROSOFT LEARN - API
ACCESS]

MATURITY AND OPERATIONAL COMPLEXITY

[MICROSOFT DOCS - ZERO TRUST POLICIES]

ETHICAL CONSIDERATIONS, SCOPE AND DELIVERABLES

TIMELINE

ALIGNMENT TO
CYBOK AND BCS
STANDARDS




ETHICAL
CONSIDERATIONS

**NO REAL DATA: FICTITIOUS IDENTITIES
ISOLATED AZURE ENVIRONMENT, NON-PRODUCTION**

**CONSENT NOT REQUIRED
COMPLIANCE WITH UNIVERSITY ETHICAL GUIDELINES**


INCLUDED SCOPE

**ADVANCED IAM CONFIGURATION
SECURING AND TESTING API ACCESS TO BROKEN CRYSTAL
EVALUATION OF ZERO TRUST ROBUSTNESS AND
EFFECTIVENESS**

**SIMULATION OF INCIDENTS: PRIVILEGE ESCALATION, TOKEN
REUSE, CONSENT PHISHING
DOCUMENTATION AND RECOMMENDATIONS**


EXPECTED DELIVERABLES

**DETAILED IAM POLICY CONFIGURATIONS
OPERATIONAL ISOLATED AZURE TENANT
EXPERIMENTATION REPORTS**

**COMPLETE ACTIVITY LOGS AZURE / ENTRA ID / DEFENDER /
SENTINEL
METHODOLOGICAL GUIDES
PRACTICAL RECOMMENDATIONS**

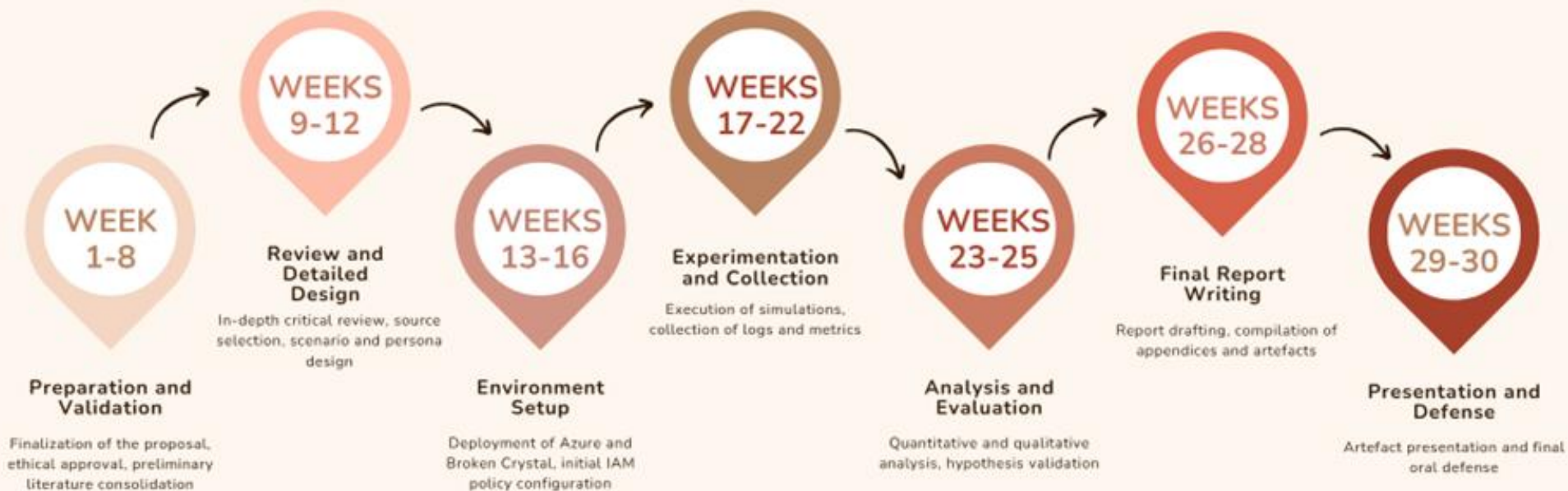


EXCLUDED SCOPE :
**TRADITIONAL NETWORK ATTACKS
TESTING IN REAL PRODUCTION ENVIRONMENTS
ANALYSES OUTSIDE ENTRA ID IAM**

TIMELINE

ALIGNMENT TO
CYBOK AND BCS
STANDARDS

RISK ASSESSMENT



ALIGNMENT TO CYBOK AND BCS STANDARDS

RISK ASSESSMENT

CONCLUSION
& REFERENCES



CYBOK KNOWLEDGE AREAS (2021)



AUTHENTICATION, AUTHORISATION & ACCOUNTABILITY
CLOUD SECURITY



RISK MANAGEMENT & GOVERNANCE
SECURITY OPERATIONS & INCIDENT MANAGEMENT
PRIVACY & ONLINE RIGHTS

BCS COMPLIANCE (BCS, 2019)



CONCRETE ARTEFACT
SCIENTIFIC ORIGINALITY



SYSTEMATIC APPROACH
ETHICAL RESPONSIBILITY

RISK ASSESSMENT

CONCLUSION
& REFERENCES

REFERENCES



RISKS



TECHNICAL

AZURE COMPLEXITY→ FEASIBILITY TESTS, AUTOMATION
DATA LOSS→ BACKUPS, INTEGRITY CHECKS

QUOTA LIMITS→ CHECKS, BUDGETING
AZURE DOWNTIME → BUFFERS, SNAPSHOTS



METHODOLOGICAL

IAM LEARNING CURVE → TRAINING, DOCUMENTATION

LIMITED LITERATURE → BROADENED RESEARCH
TIME CONSTRAINTS → PRIORITISATION, BUFFER TIME



ORGANIZATIONAL

SCHEDULE DELAYS→ MILESTONE PLANNING

DISCLOSURE RISKS→ ANONYMISATION, VALIDATION



CONTINUOUS MONITORING
CORRECTIVE MEASURES READY
SCIENTIFIC RELIABILITY



REFERENCES

CONCLUSION & REFERENCES

REFERENCES

BCS - The Chartered Institute for IT, 2019. BCS Project Requirements. BCS - The Chartered Institute for IT. Available at: <https://www.bcs.org> [Accessed 15 June 2025].

Bobbert, Y. and Scheerder, J., 2022. Zero Trust Validation: from Practice to Theory: An empirical research project to improve Zero Trust implementations. 2022 IEEE 29th Annual Software Technology Conference (STC), pp.93-104. Available at: <https://ieeexplore.ieee.org/document/9951014> [Accessed 10 June 2025].

Bush, N. and Mashatan, A., 2022. From Zero to One Hundred: Demystifying zero trust and its implications on enterprise people, process, and technology. ACM Digital Library. Available at: <https://dl.acm.org/doi/abs/10.1145/3561799> [Accessed 9 June 2025].

Chandramouli, R. and Butcher, Z., 2023. A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Location Environments. NIST Special Publication 800-207A. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207A.pdf> [Accessed 8 June 2025].

European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation). Official Journal of the European Union, L119, pp.1-88. Available at: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679> [Accessed 14 June 2025].

Kodakandla, N., 2024. Securing Cloud-Native Infrastructure with Zero Trust Architecture. ResearchGate. Available at: https://www.researchgate.net/profile/Naveen-Kodakandla/publication/388755287_Securing_Cloud-Native_Infrastructure_with_Zero_Trust_Architecture/links/67a4d94a8311ce680c5868c0/Securing-Cloud-Native-Infrastructure-with-Zero-Trust-Architecture.pdf [Accessed 5 June 2025].

Levine, A. and Tucker, B.A., 2023. Zero Trust Architecture: Risk Discussion. Digital Threats: Research and Practice, 4(1), Article 15. Available at: <https://doi.org/10.1145/3573892> [Accessed 11 June 2025].

Microsoft Docs, 2024. Azure AD Conditional Access policies. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/howto-conditional-access-policy-all-users> [Accessed 27 June 2025].

Microsoft Docs, 2024. Azure AD Identity Governance - Access Reviews. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/governance/access-reviews-overview> [Accessed 24 June 2025].

Microsoft Docs, 2024. Azure AD Identity Protection. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/identity-protection/overview-identity-protection> [Accessed 25 June 2025].

Microsoft Docs, 2024. Azure AD Identity Protection risk detections. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/identity-protection/howto-identity-protection-risk-policies> [Accessed 28 June 2025].



REFERENCES

Microsoft Docs, 2024. Azure AD Privileged Identity Management. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/privileged-identity-management/pim-configure> [Accessed 26 June 2025].

Microsoft Docs, 2024. Integrate Azure AD logs with Azure Sentinel. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/sentinel/connect-azure-active-directory> [Accessed 24 June 2025].

Microsoft Docs, 2024. Lifecycle workflows in Azure AD Identity Governance. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/governance/lifecycle-workflows-overview> [Accessed 26 June 2025].

Microsoft Docs, 2024. Secure access to Azure resources with Azure AD. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/role-based-access-control/overview> [Accessed 29 June 2025].

Microsoft Docs, 2024. Zero Trust identity and device access policies. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/security/zero-trust/deploy/identity-device-access-policies> [Accessed 30 June 2025].

Microsoft Learn, 2024. Manage API access with Azure AD. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/develop/v2-permissions-and-consent> [Accessed 29 June 2025].

Microsoft Learn, 2024. Multi-Factor Authentication. Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/authentication/concept-mfa-howitworks> [Accessed 27 June 2025].

Microsoft Learn, 2024. What is Conditional Access? Microsoft Learn. Available at: <https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/overview> [Accessed 25 June 2025].

Michael, J.B., Dinolt, G.C., Cohen, F.B. and Wijesekera, D., 2022. Can You Trust Zero Trust? IEEE Computer, 55(8), pp.103-105. Available at: <https://ieeexplore.ieee.org/document/9847325> [Accessed 12 June 2025].

Rashid, A., Chivers, H., Danezis, G., Hankin, C., Martin, A. and Sasse, M.A., eds., 2021. The Cyber Security Body of Knowledge (CyBOK), Version 1.1. University of Bristol. Available at: https://www.cybok.org/knowledgebase1_1/ [Accessed 03 June 2025].

Rose, S., Borchert, O., Mitchell, S. and Connelly, S., 2020. Zero Trust Architecture. NIST Special Publication 800-207. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf> [Accessed 7 June 2025].

Shore, M., Zeadally, S. and Keshariya, A., 2021. Zero trust: The what, how, why, and when. IEEE Communications Magazine. Available at: <https://ieeexplore.ieee.org/abstract/document/9585170> [Accessed 6 June 2025].

Teerakanok, S., Uehara, T. and Inomata, A., 2021. Migrating to Zero Trust Architecture: Reviews and Challenges. Security and Communication Networks. Available at: <https://onlinelibrary.wiley.com/doi/pdf/10.1155/2021/9947347> [Accessed 13 June 2025].